

LUMIBANK

Sistema Bancario — Normative ISO Applicabili

Versione 1.0 | Anno 2026

Documento per conformità normativa e audit interno

1. Introduzione

Il presente documento descrive le principali normative ISO applicabili al sistema LumiBank, una piattaforma bancaria web che gestisce conti correnti, operazioni finanziarie, prestiti/mutui e dati personali dei clienti.

LumiBank offre le seguenti funzionalità principali:

- Gestione conti correnti (Canone Fisso, Senza Canone, Conto Deposito)
- Operazioni bancarie: versamenti, prelievi, bonifici
- Gestione prestiti e mutui con calcolo rata e tasso di interesse
- Portale clienti con autenticazione e storico movimenti
- Dashboard staff con statistiche e gestione conti
- Generazione IBAN in formato italiano (IT60...)
- Notifiche via email per ogni operazione

Le normative elencate in questo documento costituiscono il riferimento di conformità per lo sviluppo, la sicurezza e l'operatività del sistema.

2. Sicurezza delle Informazioni — ISO/IEC 27001 e 27002

Poiché LumiBank tratta dati finanziari e personali sensibili, la norma ISO/IEC 27001 è la più critica dell'intero framework di conformità.

2.1 ISO/IEC 27001:2022 — Sistema di Gestione della Sicurezza delle Informazioni (ISMS)

Questa norma definisce i requisiti per istituire, implementare, mantenere e migliorare continuamente un Sistema di Gestione della Sicurezza delle Informazioni (ISMS).

Applicazione a LumiBank

- Classificazione dei dati: dati cliente (email, nome, cognome, password), saldi, movimenti, IBAN, dettagli prestiti
- Controllo degli accessi: distinzione ruoli staff/cliente con autenticazione separata
- Crittografia: le password sono codificate tramite Base64 (da aggiornare con hashing crittografico come bcrypt)
- Gestione incidenti: procedure di risposta a violazioni dei dati e accessi non autorizzati
- Continuità operativa: backup dei dati su localStorage e piani di ripristino

Controllo ISO 27001	Area LumiBank	Stato
A.5 – Politiche sicurezza informazioni	Policy accesso staff e clienti	Da formalizzare
A.8 – Gestione asset	Dati clienti, conti, movimenti	Implementato (localStorage)
A.9 – Controllo accessi	Login staff/cliente separato	Implementato
A.10 – Crittografia	Password hashing	Parziale (Base64)
A.12 – Sicurezza operativa	Log operazioni, email notifiche	Implementato
A.16 – Gestione incidenti	Procedure risposta breach	Da definire
A.17 – Continuità operativa	Backup e recovery dati	Da implementare

2.2 ISO/IEC 27002:2022 — Controlli di Sicurezza

Fornisce linee guida pratiche per implementare i controlli di sicurezza richiesti dalla ISO 27001. Per LumiBank sono particolarmente rilevanti:

- Controllo 8.3 — Uso accettabile degli asset informativi (dati bancari dei clienti)
- Controllo 8.5 — Autenticazione sicura (rafforzamento login con MFA)
- Controllo 8.12 — Prevenzione della perdita di dati (DLP per movimenti e IBAN)
- Controllo 8.24 — Uso della crittografia (sostituire Base64 con algoritmi forti)

2.3 ISO/IEC 27005:2022 — Gestione del Rischio

Definisce il processo di valutazione e trattamento del rischio per la sicurezza delle informazioni.

- Identificazione rischi: SQL injection, XSS, accessi non autorizzati, furto sessione
- Valutazione impatto: perdita dati finanziari, violazione privacy, frode
- Trattamento: implementazione controlli tecnici e procedurali

3. Protezione Dati Personali — ISO/IEC 29100 e 27018

3.1 ISO/IEC 29100:2011 — Framework Privacy

Fornisce un framework per la protezione dei dati personali nei sistemi IT. LumiBank raccoglie e tratta dati personali identificativi (PII) dei clienti.

Principi applicabili

- Consenso e scelta: raccolta esplicita del consenso all'apertura conto
- Limitazione della finalità: i dati sono usati solo per la gestione bancaria
- Minimizzazione dei dati: raccogliere solo ciò che è necessario (email, nome, cognome)
- Accuratezza: possibilità per il cliente di aggiornare i propri dati
- Conservazione limitata: definire retention period per movimenti e dati inattivi
- Sicurezza: protezione tecnica e organizzativa dei dati personali

3.2 ISO/IEC 27018:2019 — Protezione PII nel Cloud

Applicabile se LumiBank viene ospitata su infrastruttura cloud. Stabilisce controlli per la protezione di informazioni personali identificabili nei servizi cloud pubblici.

- Notifica violazioni dati ai titolari del trattamento
- Divieto di uso dei dati PII per scopi di marketing senza consenso
- Accesso ai dati solo per erogazione del servizio

4. Servizi Finanziari — ISO 20022 e Standard Bancari

4.1 ISO 20022 — Messaggistica Finanziaria Universale

ISO 20022 è lo standard internazionale per i messaggi di pagamento e la comunicazione interbancaria. È adottato da SEPA, TARGET2, SWIFT e la maggior parte dei circuiti europei.

Rilevanza per LumiBank

- Struttura dei messaggi di bonifico (Credit Transfer — pacs.008)
- Formato IBAN: LumiBank genera IBAN in formato IT60 + codice banca + filiale + numero conto
- Causali e codici operazione standardizzati per i movimenti
- Riconciliazione estratti conto e rendicontazione

Tipo Messaggio ISO 20022	Descrizione	Funzione LumiBank
pacs.008	Credit Transfer Initiation	Bonifici in uscita
pacs.002	Payment Status Report	Conferma operazioni
camt.052	Bank to Customer Account Report	Movimenti in tempo reale
camt.053	Bank to Customer Statement	Estratto conto mensile
camt.054	Debit Credit Notification	Notifica versamenti/prelievi

4.2 ISO 13616 — Formato IBAN

Definisce il formato e la struttura dell'International Bank Account Number (IBAN). LumiBank genera IBAN nel formato italiano:

IT60 + [Codice Banca 5 cifre] + [Codice Filiale 5 cifre] + [N. Conto 12 cifre]

- Lunghezza totale IBAN italiano: 27 caratteri
- Verifica tramite algoritmo MOD-97 (check digit)
- Conformità obbligatoria per operazioni SEPA

5. Qualità del Software — ISO/IEC 25010

ISO/IEC 25010 (SQuaRE) definisce il modello di qualità per i sistemi software. Per LumiBank le caratteristiche principali sono:

Caratteristica	Sottocaratteristica	Applicazione LumiBank
Funzionalità	Completezza funzionale	Gestione conti, operazioni, prestiti, dashboard
Affidabilità	Disponibilità	Uptime sistema bancario, gestione errori DB
Usabilità	Apprendibilità	Interfaccia intuitiva staff e clienti
Sicurezza	Riservatezza	Dati finanziari e personali cifrati
Sicurezza	Autenticità	Login separato staff/cliente con verifica
Manutenibilità	Modularità	Architettura OOP (CardRenderer, StatsRenderer)
Portabilità	Adattabilità	Web app responsive multi-dispositivo
Prestazioni	Efficienza temporale	Operazioni in tempo reale, grafici Chart.js

6. Accessibilità Web — ISO 9241-171 e WCAG

6.1 ISO 9241-171:2008 — Ergonomia del Software Accessibile

Fornisce linee guida per la progettazione di software accessibile. LumiBank dovrebbe conformarsi ai seguenti requisiti:

- Supporto per tecnologie assistive (screen reader)
- Contrasto colori adeguato per testo e interfaccia
- Navigazione da tastiera per tutte le funzionalità
- Messaggi di errore chiari e descrittivi
- Etichette ARIA per elementi interattivi

6.2 Riferimento WCAG 2.1 — Web Content Accessibility Guidelines

Pur non essendo una norma ISO diretta, le WCAG 2.1 sono richiamate da ISO 9241-171 e costituiscono il riferimento tecnico per l'accessibilità web.

- Livello AA obbligatorio per servizi bancari online in Italia (D.Lgs. 106/2018)
- Principi: Percepibile, Operabile, Comprensibile, Robusto

7. Gestione dei Rischi Operativi — ISO 31000

7.1 ISO 31000:2018 — Gestione del Rischio

Framework internazionale per la gestione del rischio applicabile a qualsiasi tipo di organizzazione. Per LumiBank:

Categoria Rischio	Scenario	Trattamento Suggestito
Rischio tecnologico	Perdita dati localStorage	Backup server-side, IndexedDB
Rischio sicurezza	Password in Base64 compromessa	Migrazione a bcrypt/Argon2
Rischio operativo	Invio email non riuscito (EmailJS)	Retry automatico, log errori
Rischio conformità	GDPR non rispettato	DPA, privacy policy, consensi
Rischio disponibilità	Downtime sistema	Ridondanza, SLA definiti
Rischio frode	Accesso non autorizzato a conti	MFA, session timeout, audit trail

8. Continuità Operativa — ISO 22301

8.1 ISO 22301:2019 — Business Continuity Management

Definisce i requisiti per implementare un Sistema di Gestione della Continuità Operativa (BCMS). Per un sistema bancario è fondamentale garantire la continuità del servizio.

- Recovery Time Objective (RTO): tempo massimo accettabile di interruzione del servizio
- Recovery Point Objective (RPO): perdita massima accettabile di dati
- Piano di ripristino in caso di crash del browser o corruzione del localStorage
- Procedure di comunicazione ai clienti in caso di interruzione del servizio
- Test periodici del piano di continuità

9. Riepilogo Normative e Priorità

Norma ISO	Titolo	Priorità	Area
ISO/IEC 27001:2022	Sicurezza Informazioni (ISMS)	CRITICA	Sicurezza
ISO/IEC 27002:2022	Controlli di Sicurezza	CRITICA	Sicurezza
ISO 20022	Messaggistica Finanziaria	ALTA	Finanza
ISO 13616	Formato IBAN	ALTA	Finanza
ISO/IEC 29100:2011	Framework Privacy	ALTA	Privacy
ISO/IEC 25010	Qualità del Software	ALTA	Qualità
ISO/IEC 27005:2022	Gestione Rischio Sicurezza	MEDIA	Sicurezza
ISO/IEC 27018:2019	PII nel Cloud	MEDIA	Privacy
ISO 31000:2018	Gestione del Rischio	MEDIA	Risk Mgmt
ISO 9241-171	Accessibilità Software	MEDIA	UX
ISO 22301:2019	Continuità Operativa	MEDIA	Operatività

10. Azioni Correttive Prioritarie

Sulla base dell'analisi del codice sorgente di LumiBank, si raccomandano le seguenti azioni immediate:

Priorità	Azione	Norma di Riferimento	Impegno Stimato
P1 — Critica	Sostituire Base64 con bcrypt/Argon2 per le password	ISO 27001 A.10, ISO 27002 8.24	2-3 giorni
P1 — Critica	Migrare da localStorage a storage server-side cifrato	ISO 27001 A.8, ISO 22301	1-2 settimane
P1 — Critica	Implementare session timeout e token JWT	ISO 27001 A.9, ISO 27002 8.5	3-5 giorni
P2 — Alta	Validare formato IBAN con algoritmo MOD-97	ISO 13616	1 giorno
P2 — Alta	Aggiungere audit trail per tutte le operazioni	ISO 27001 A.12	3-4 giorni
P2 — Alta	Definire e documentare la Privacy Policy	ISO/IEC 29100, GDPR	2-3 giorni
P3 — Media	Implementare MFA per accesso staff	ISO 27002 8.5	1 settimana
P3 — Media	Strutturare messaggi operazione	ISO 20022	1-2 settimane

Priorità	Azione	Norma di Riferimento	Impegno Stimato
	su ISO 20022		
P3 — Media	Effettuare audit accessibilità WCAG 2.1 AA	ISO 9241-171	3-5 giorni

Appendice — Riferimenti Normativi

- ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection
- ISO/IEC 27002:2022 — Information security controls
- ISO/IEC 27005:2022 — Guidance on managing information security risks
- ISO/IEC 27018:2019 — Protection of PII in public clouds
- ISO/IEC 29100:2011 — Privacy framework
- ISO/IEC 25010:2011 — Systems and software quality models
- ISO 20022 — Universal financial industry message scheme
- ISO 13616:2020 — Financial services — International bank account number (IBAN)
- ISO 31000:2018 — Risk management — Guidelines
- ISO 9241-171:2008 — Ergonomics of human-system interaction — Accessibility
- ISO 22301:2019 — Business continuity management systems
- Regolamento (UE) 2016/679 (GDPR) — Protezione dati personali
- Direttiva (UE) 2015/2366 (PSD2) — Servizi di pagamento nel mercato interno